(주)알바월드

개인정보 관리체계 진단 결과보고서

BoB 14기 보안 컨설팅 손효림

조성규 멘토님 과제

목차

01 개인정보 흐름도

02 개인정보 수집 동의서 진단 결과

03 개인정보 처리방침 진단 결과

04 개인정보 위탁계약서 진단 결과

05 개인정보처리시스템 진단 결과

06 결론

(주)알바월드

개인정보 흐름도

개인정보 흐름도

개인정보 생명주기	정보주체/ 개인정보취급자	개인정보 처리 흐름	외부연계· 제공	처리 개인정보
수집	정보주체	홈페이지 → ① 회원가입 → D		① 회원가입 이메일, 비밀번호, 성명, 핸드폰번호, 공인영어성적, 대학교명, 학과명, 학점, 질병유무, 보유질병명, 자기소개서
보유 · 이용 · 제공	시스템운영자 회원관리자	B 망분리PC 보안USB로 이동 ② 인터넷PC 사용자 계정 생성 및 삭제 ② 접근권한 부여 A 엑셀 다운로드 비밀번호 DB 서버 ③ 회원관리프로그램 웹 서버 AI 서류전형 C 접속기록 저장 고객 상담 이용자 정보 조회/수정 E G 로그 서버 AI F 로그 관리 인터넷PC	㈜ABC SMS 발송 프로그램 이메일로 전송 ②	② 엑셀 다운로드, 보안 USB로 이동, 이메일로 전송 핸드폰번호 ③ AI 서류전형 자기소개서, 학부성적 등
파기	정보주체	회원탈퇴 회원정보 (탈퇴 후 즉시) 아르바이트 지원 탈락자 정보 (탈락 결정 5일 이내) 웹페이지 접속 (3개월간 보존) 소비자 불만 또는 분쟁처리 (5년간 보존) 계약 또는 청약철회, 대금결제 및 재화 공급 (5년간 보존)		
주요 업무흐름 설명	- 사이트 회원가입 기능을 통해 정보주체의 개인정보를 수집하여 회사 내 전산실에 있는 DB서버에 저장하여 보관함 - 회원관리프로그램으로 이용자 정보를 조회하며, 회원정보는 탈퇴 후 즉시 삭제 또는 법령에 따른 기간동안 보존 (아르바이트 탈락자는 결정 5일 이내 파기) - 개인정보취급자 중 시스템운영자는 사용자 계정 생성 및 삭제, 접근권한 부여, 로그 관리, 엑셀 다운로드가 가능하며, 인터넷이 차단된 망분리 PC를 사용함 - 시스템운영자는 일반업무는 인터넷PC를 이용하고 망분리PC에서 인터넷PC로 자료 이동 시 보안USB를 이용하며, 재택근무가 가능함 - 개인정보취급자 중 회원관리자는 인터넷이 가능한 PC를 이용하여 이용자 정보 조회/수정, 고객상담 업무를 수행하고 재택근무가 가능함 - 합격 여부 및 일자리 소개를 위해 이용자들의 '핸드폰번호'를 ㈜ABC 수탁사(SMS 발송 업체)에 시스템운영자가 인터넷PC에서 엑셀 첨부 이메일로 제공함 - ㈜ABC사는 자체 보유하고 있는 SMS 발송 프로그램에 이용자 핸드폰번호가 기입된 엑셀파일 업로드 및 문자내용을 입력하여, SMS 발송 서비스 제공			
우려사항	A. 개인정보취급자의 퇴직 및 인사이동 발생 시 계정 및 접근 권한을 지체없이 변경 또는 말소하지 않음 (통제항목 2.2.5.2) B. 외부에서 개인정보처리시스템에 접속할 경우, 인증서, 보안토큰, 일회용 비밀번호 등 안전한 인증수단을 적용하고 있지 않음 (통제항목 2.5.3.2) C. 전송구간에 대해 안전하지 않은 암호 알고리즘으로 암호화하고 있음 (통제항목 2.7.1.1) D. 사용자 비밀번호를 DB에 저장 시 일방향 암호화하고 있지 않음 (통제항목 2.7.1.1) E. 개인정보처리시스템의 접속 기록을 월 1회 이상 점검하고 있지 않음 (통제항목 2.9.5.3) F. '이용자 정보 추출' 화면에서 화면에 출력되는 회원정보에 대해 별도 마스킹을 적용하지 않음 (통제항목 2.6.3.5) G. '접속로그 관리' 화면에서 처리한 정보주체의 정보에 대한 기록을 확인할 수 없음 (통제항목 2.9.4.3)			

개인정보 흐름도

기호	설명
개인정보취급자 정보주체	개인정보 취급자는 특정 색 바탕화면으로 표기 정보주체는 흰색 바탕화면으로 표기
→ ⇢	온라인의 개인정보 흐름은 실선으로 표기 오프라인의 개인정보 흐름은 점선으로 표기
→ DB 암호화 (비밀번호, 주민등록번호)	암호화되어 전송 시 **붉은 색**으로 굵게 표기 암호화되어 보관하는 경우, DB에 암호화 항목을 박스로 별도 표시
온라인 처리업무 오프라인 처리업무 온/오프라인 처리업무	온라인을 통한 개인정보 **수집·이용** 업무처리는 특정 색 바탕화면으로 표기 오프라인을 통한 개인정보 **수집·이용** 업무처리는 흰색 바탕화면으로 표기 온/오프라인을 통한 개인정보 **수집·이용** 업무처리는 흰색 바탕화면으로 표기
시스템 DB 캐비닛	온라인을 통한 개인정보 **보유** 업무처리는 실선으로 표기 오프라인을 통한 개인정보 **보유** 업무처리는 점선으로 표기
외부 시스템 내부 시스템	외부 기관을 통한 개인정보 **제공 및 연계** 업무처리는 특정 색 바탕화면으로 표기 내부 기관을 통한 개인정보 **연계** 업무처리는 흰색 바탕화면으로 표기

개인정보 흐름도

기호	설명
온라인 파기 / 오프라인 파기	온라인을 통한 개인정보 **파기** 업무처리는 특정 색 바탕화면으로 표기 오프라인을 통한 개인정보 **파기** 업무처리는 흰색 바탕화면으로 표기
온라인 처리 시스템 / 오프라인 처리	정보 입력, 조회 등 온라인을 통한 개인정보 업무처리 화면은 특정 색 바탕화면으로 표기 신청서 접수 등 오프라인을 통한 개인정보 업무처리 행위는 흰색 바탕화면으로 표기
	개인정보 침해요인 표기
	개인정보 단말PC 표기
	개인정보 문서(스캔파일) 표기
1 2 3 4 5	처리되는 개인정보를 구분하기 위한 숫자 표기

(주)알바월드

개인정보 수집 동의서 진단 결과

개인정보 수집 동의서 진단 결과 (1/5)

통제항목 번호	점검 기준
3.1.1.3	정보주체에게 개인정보 수집 동의를 받는 경우 관련 내용을 명확하게 고지하고 법령에서 정한 중요한 내용에 대해 알아보기 쉽게 표시하고 있는가?

취약점	법령근거	개선방안
■ 개인정보 수집·이용 내역 수집·이용 목적 / 항목 / 보유 및 이용기간 / 동의 여부 홈페이지 회원 관리 및 일자리 소개 / 이메일, 비밀번호, 성명, 핸드폰 번호, 공인영어성적, 대학교명, 학과명, 학점, 질병유무, 보유질병명, 자기소개서 / 회원탈퇴 후 즉시 삭제 또는 법령에 따른 보존 기간 (단, 아르바이트 지원 탈락자의 경우는 탈락 결정 후 5일 이내 파기) / □ 동의함 □ 동의하지 않음 동의를 거부할 권리가 있다는 사실 및 동의 거부에 따른 불이익이 있는 경우에는 그 불이익의 내용이 누락됨.	개인정보 보호법 제15조(개인정보의 수집 · 이용) ② 개인정보처리자는 제1항제1호에 따른 동의를 받을 때에는 다음 각 호의 사항을 정보주체에게 알려야 한다. 다음 각 호의 어느 하나의 사항을 변경하는 경우에도 이를 알리고 동의를 받아야 한다. 1. 개인정보의 수집·이용 목적 2. 수집하려는 개인정보의 항목 3. 개인정보의 보유 및 이용 기간 4. 동의를 거부할 권리가 있다는 사실 및 동의 거부에 따른 불이익이 있는 경우에는 그 불이익의 내용	개인정보 수집·이용 동의 시, 동의를 거부할 권리가 있다는 사실과 동의 거부 시 불이익 내용을 정보주체에게 알리도록 수정.

개인정보 수집 동의서 진단 결과 (2/5)

통제항목 번호	점검 기준
3.1.1.3	정보주체에게 개인정보 수집 동의를 받는 경우 관련 내용을 명확하게 고지하고 법령에서 정한 중요한 내용에 대해 알아보기 쉽게 표시하고 있는가?

취약점	법령근거	개선방안
▌개인정보 수집·이용 내역 수집·이용 목적 / 항목 홈페이지 회원 관리 및 일자리 소개 / 이메일, 비밀번호, 성명, 핸드폰 번호, 공인영어성적, 대학교명, 학과명, 학점, 질병유무, 보유질병명, 자기소개서 보유 및 이용기간 / 동의 여부 회원탈퇴 후 즉시 삭제 또는 법령에 따른 보존 기간 (단, 아르바이트 지원 탈락자의 경우는 탈락 결정 후 5일 이내 파기) / □ 동의함 □ 동의하지 않음 중요한 내용을 글씨의 크기, 색깔, 굵기 또는 밑줄 등을 통하여 그 내용이 명확히 표시되도록 하고 있지 않음.	개인정보 보호법 제22조(동의를 받는 방법) ② 개인정보처리자는 제1항의 동의를 서면(「전자문서 및 전자거래 기본법」 제2조제1호에 따른 전자문서를 포함한다)으로 받을 때에는 개인정보의 수집·이용 목적, 수집·이용하려는 개인정보의 항목 등 대통령령으로 정하는 중요한 내용을 보호위원회가 고시로 정하는 방법에 따라 명확히 표시하여 알아보기 쉽게 하여야 한다. 개인정보 보호법 시행령 제17조(동의를 받는 방법) ③ 법 제22조제2항에서 "대통령령으로 정하는 중요한 내용"이란 다음 각 호의 사항을 말한다. 1. 개인정보의 수집·이용 목적 중 재화나 서비스의 홍보 또는 판매 권유 등을 위하여 해당 개인정보를 이용하여 정보주체에게 연락할 수 있다는 사실 2. 처리하려는 개인정보의 항목 중 다음 각 목의 사항 가. 민감정보 나. 제19조제2호부터 제4호까지의 규정에 따른 여권번호, 운전면허의 면허번호 및 외국인등록번호 3. 개인정보의 보유 및 이용 기간(제공 시에는 제공받는 자의 보유 및 이용 기간을 말한다) 4. 개인정보를 제공받는 자 및 개인정보를 제공받는 자의 개인정보 이용 목적	개인정보 수집·이용 동의를 받을 때, 중요한 내용(민감정보, 보유 및 이용 기간)을 글씨 크기, 색깔, 굵기 또는 밑줄 등을 활용하여 명확하게 표시하도록 수정.

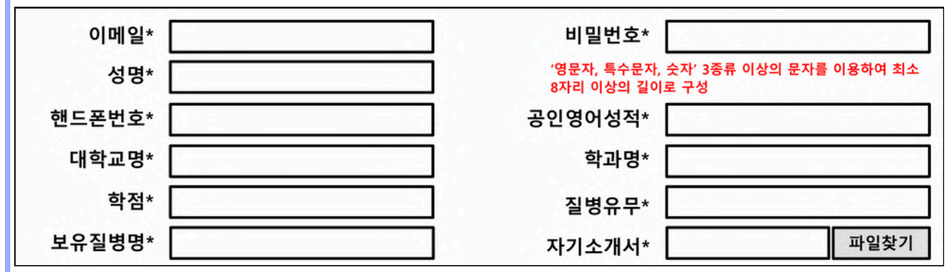
개인정보 수집 동의서 진단 결과 (3/5)

통제항목 번호	점검 기준
3.1.4.1	민감정보는 정보주체로부터 별도의 동의를 받거나 관련 법령에 근거가 있는 경우에만 처리하고 있는가?

취약점	법령근거	개선방안
■ 개인정보 수집·이용 내역 수집·이용 목적 / 항목 홈페이지 회원 관리 및 일자리 소개 / 이메일, 비밀번호, 성명, 핸드폰 번호, 공인영어성적, 대학교명, 학과명, 학점, 질병유무, 보유질병명, 자기소개서 보유 및 이용기간 / 동의 여부 회원탈퇴 후 즉시 삭제 또는 법령에 따른 보존 기간 (단, 아르바이트 지원 탈락자의 경우는 탈락 결정 후 5일 이내 파기) / □ 동의함 □ 동의하지 않음 질병유무, 보유질병명은 민감정보임에도 수집 시 다른 항목과 구분하여 별도로 동의를 받고 있지 않음.	개인정보 보호법 제23조(민감정보의 처리 제한) ① 개인정보처리자는 사상·신념, 노동조합·정당의 가입·탈퇴, 정치적 견해, 건강, 성생활 등에 관한 정보, 그 밖에 정보주체의 사생활을 현저히 침해할 우려가 있는 개인정보로서 대통령령으로 정하는 정보(이하 "민감정보"라 한다)를 처리하여서는 아니 된다. 다만, 다음 각 호의 어느 하나에 해당하는 경우에는 그러하지 아니하다. 1. 정보주체에게 제15조제2항 각 호 또는 제17조제2항 각 호의 사항을 알리고 다른 개인정보의 처리에 대한 동의와 별도로 동의를 받은 경우 개인정보 보호법 제22조(동의를 받는 방법) ① 개인정보처리자는 이 법에 따른 개인정보의 처리에 대하여 정보주체(제22조의2제1항에 따른 법정대리인을 포함한다. 이하 이 조에서 같다)의 동의를 받을 때에는 각각의 동의 사항을 구분하여 정보주체가 이를 명확하게 인지할 수 있도록 알리고 동의를 받아야 한다. 이 경우 다음 각 호의 경우에는 동의 사항을 구분하여 각각 동의를 받아야 한다. 5. 제23조제1항제1호에 따라 동의를 받는 경우	민감정보인 '질병유무'와 '보유질병명'을 수집할 때 다른 개인정보와 구분하여 별도로 선택 동의를 받도록 수정.

개인정보 수집 동의서 진단 결과 (4/5)

통제항목 번호	점검 기준
3.1.2.2	정보주체의 동의를 받아 개인정보를 수집하는 경우 필요한 최소한의 정보 외의 개인정보 수집에는 동의하지 않을 수 있다는 사실을 구체적으로 알리고 있는가?

취약점	법령근거	개선방안
 선택 동의 항목에 '(선택)' 표시를 하지 않고 있음.	개인정보 보호법 제16조(개인정보의 수집 제한) ② 개인정보처리자는 정보주체의 동의를 받아 개인정보를 수집하는 경우 필요한 최소한의 정보 외의 개인정보 수집에는 동의하지 아니할 수 있다는 사실을 구체적으로 알리고 개인정보를 수집하여야 한다. 개인정보 보호법 시행령 제17조(동의를 받는 방법) ④ 개인정보처리자는 정보주체로부터 법 제22조제1항 각 호에 따른 동의를 받으려는 때에는 정보주체가 동의 여부를 선택할 수 있다는 사실을 명확하게 알 수 있도록 표시해야 한다.	선택 동의 항목에 '(선택)' 표시를 추가하여 정보주체가 동의 여부를 명확하게 선택할 수 있도록 수정.

개인정보 수집 동의서 진단 결과 (5/5)

통제항목 번호	점검 기준
3.1.1.3	정보주체에게 개인정보 수집 동의를 받는 경우 관련 내용을 명확하게 고지하고 법령에서 정한 중요한 내용에 대해 알아보기 쉽게 표시하고 있는가?

취약점	법령근거	개선방안
당사는 아르바이트 지원자 합격 여부 결정을 위해 아래와 같이「개인정보 보호법」제37조의2 제1항에 따라 완전히 자동화된 시스템으로 귀하의 개인정보를 처리하는 자동화된 결정을 하고 있음을 알려드립니다. ■ 자동화된 결정이 이루어지는 업무의 내용과 목적 아르바이트 지원자 서류전형 단계에서 채용 기준에 따라 지원자의 업무 역량을 평가하여 합격 여부를 결정하기 위해 인공지능(AI)을 활용하여 완전히 자동화된 시스템에 의한 결정(불합격 결정)을 하고 있습니다. ■ 자동화된 결정 과정에서 처리되는 주요 개인정보의 유형 아르바이트 지원자의 서류전형 과정에서 AI 자동화된 시스템을 통해 수집하는 자기소개서, 공인영어시험 점수, 학부성적 등을 분석하여 서류전형 합격 여부를 결정하고 있습니다. 위 자동화된 결정에 동의합니다. □ 동의함 □ 동의하지 않음 동의를 거부할 권리가 있다는 사실 및 동의 거부에 따른 불이익이 있는 경우에는 그 불이익의 내용이 누락됨.	개인정보 보호법 제15조(개인정보의 수집 · 이용) ② 개인정보처리자는 제1항제1호에 따른 동의를 받을 때에는 다음 각 호의 사항을 정보주체에게 알려야 한다. 다음 각 호의 어느 하나의 사항을 변경하는 경우에도 이를 알리고 동의를 받아야 한다. 1. 개인정보의 수집·이용 목적 2. 수집하려는 개인정보의 항목 3. 개인정보의 보유 및 이용 기간 4. 동의를 거부할 권리가 있다는 사실 및 동의 거부에 따른 불이익이 있는 경우에는 그 불이익의 내용	자동화된 결정에 대한 동의를 받을 때, 동의를 거부할 권리가 있다는 사실과 동의 거부 시 불이익 내용을 명확하게 고지하도록 수정.

(주)알바월드

개인정보 처리방침 진단 결과

개인정보 처리방침 진단 결과 (1/14)

통제항목 번호	점검 기준
3.5.1.1	개인정보 처리방침을 법령에서 요구하는 내용을 모두 포함하여 알기 쉬운 용어로 구체적이고 명확하게 작성하였는가?

취약점	법령근거	개선방안
 ‘개인정보 처리방침’이 아닌 ‘개인정보 취급방침’이라는 명칭을 사용하여 게시하고 있음.	개인정보 보호법 제30조(개인정보 처리방침의 수립 및 공개) ① 개인정보처리자는 다음 각 호의 사항이 포함된 개인정보의 처리 방침(이하 "개인정보 처리방침"이라 한다)을 정하여야 한다. 표준 개인정보 보호지침 제20조(개인정보 처리방침의 공개) ① 개인정보처리자가 법 제30조제2항에 따라 개인정보 처리방침을 수립하는 경우에는 인터넷 홈페이지를 통해 지속적으로 게재하여야 하며, 이 경우 "개인정보 처리방침"이라는 명칭을 사용하되, 글자 크기, 색상 등을 활용하여 다른 고지사항과 구분함으로써 정보주체가 쉽게 확인할 수 있도록 하여야 한다.	개인정보 처리방침의 명칭을 '개인정보 취급방침'이 아닌 '개인정보 처리방침'으로 변경.

개인정보 처리방침 진단 결과 (2/14)

통제항목 번호	점검 기준
3.4.2.1	개인정보의 보유기간 경과 또는 처리목적 달성 후에도 관련 법령 등에 따라 파기하지 않고 보존하는 경우, 관련 법령에 따른 최소한의 기간으로 한정하여 최소한의 정보만을 보존하도록 관리하고 있는가?

취약점	법령근거	개선방안
■ 개인정보의 처리 및 보유기간 회사는 이용자의 개인정보를 원칙적으로 고지 및 약정한 기간 동안 보유하며, 이용자가 홈페이지 회원탈퇴 시 지체없이 파기합니다. 단, 아르바이트를 지원한 지원자가 불합격 시는 불합격 판정 후, 1개월 이내 파기합니다. 또한, 다음과 같은 관련법령의 규정에 의하여 보존해야 할 필요가 있을 경우에는 일정기간 보유합니다. - 계약 또는 청약철회 등에 관한 기록 : 5년 - 대금결제 및 재화 등의 공급에 관한 기록 : 5년 - 소비자 불만 또는 분쟁처리에 관한 기록 : 5년 - 웹페이지 접속에 관한 기록 : 3개월 ‘소비자 불만 또는 분쟁처리에 관한 기록’은 3년간 보존해야 하지만 5년으로 오기재됨.	전자상거래 등에서의 소비자보호에 관한 법률 제6조 (거래기록의 보존 등) ① 사업자는 다음 각 호의 1에 해당하는 기간 동안 거래에 관한 기록을 보존하여야 한다. • 계약 또는 청약철회 등에 관한 기록: 5년 • 대금결제 및 재화 등의 공급에 관한 기록: 5년 • 소비자의 불만 또는 분쟁처리에 관한 기록: 3년	'소비자 불만 또는 분쟁처리에 관한 기록'의 보존 기간을 관련 법령에 따라 3년으로 수정.

개인정보 처리방침 진단 결과 (3/14)

통제항목 번호	점검 기준
3.4.2.1	개인정보의 보유기간 경과 또는 처리목적 달성 후에도 관련 법령 등에 따라 파기하지 않고 보존하는 경우, 관련 법령에 따른 최소한의 기간으로 한정하여 최소한의 정보만을 보존하도록 관리하고 있는가?

취약점	법령근거	개선방안
■ 개인정보의 처리 및 보유기간 회사는 이용자의 개인정보를 원칙적으로 고지 및 약정한 기간 동안 보유하며, 이용자가 홈페이지 회원탈퇴 시 지체없이 파기합니다. 단, 아르바이트를 지원한 지원자가 불합격 시는 불합격 판정 후, 1개월 이내 파기합니다. 또한, 다음과 같은 관련법령의 규정에 의하여 보존해야 할 필요가 있을 경우에는 일정기간 보유합니다. - 계약 또는 청약철회 등에 관한 기록 : 5년 - 대금결제 및 재화 등의 공급에 관한 기록 : 5년 - 소비자 불만 또는 분쟁처리에 관한 기록 : 5년 - 웹페이지 접속에 관한 기록 : 3개월 개인정보 보유기간 경과 후 보존하는 경우, 관련법령을 명확히 기재하고 있지 않음.	개인정보 보호법 제21조(개인정보의 파기) ① 개인정보처리자는 보유기간의 경과, 개인정보의 처리 목적 달성, 가명정보의 처리 기간 경과 등 그 개인정보가 불필요하게 되었을 때에는 지체 없이 그 개인정보를 파기하여야 한다. 다만, 다른 법령에 따라 보존하여야 하는 경우에는 그러하지 아니하다. 개인정보 보호법 제30조(개인정보 처리방침의 수립 및 공개) ① 개인정보처리자는 다음 각 호의 사항이 포함된 개인정보의 처리 방침(이하 "개인정보 처리방침"이라 한다)을 정하여야 한다. 3의2. 개인정보의 파기절차 및 파기방법(제21조제1항 단서에 따라 개인정보를 보존하여야 하는 경우에는 그 보존근거와 보존하는 개인정보 항목을 포함한다)	개인정보 보유기간 경과 후에도 법령에 따라 보존하는 경우, 보존하는 개인정보 항목과 법적 근거를 개인정보 처리방침에 명확히 기재하도록 수정. -「전자상거래 등에서의 소비자보호에 관한 법률」 -「통신비밀보호법」

개인정보 처리방침 진단 결과 (4/14)

통제항목 번호	점검 기준
3.4.1.1	개인정보의 보유기간 및 파기와 관련된 내부 정책을 수립하고 있는가?

취약점	법령근거	개선방안
보유 및 이용기간 회원탈퇴 후 즉시 삭제 또는 법령에 따른 보존 기간 (단, 아르바이트 지원 탈락자의 경우는 탈락 결정 후 5일 이내 파기) ■ 개인정보의 처리 및 보유기간 회사는 이용자의 개인정보를 원칙적으로 고지 및 약정한 기간 동안 보유하며, 이용자가 홈페이지 회원탈퇴 시 지체없이 파기합니다. 단, 아르바이트를 지원한 지원자가 불합격 시는 불합격 판정 후, 1개월 이내 파기합니다. 또한, 다음과 같은 관련법령의 규정에 의하여 보존해야 할 필요가 있을 경우에는 일정기간 보유합니다. 아르바이트 지원 탈락자의 개인정보 보유 기간이 개인정보 수집 동의서(5일 이내 파기)와 개인정보처리방침(1개월 이내 파기)이 불일치함.	개인정보 보호법 제21조(개인정보의 파기) ① 개인정보처리자는 보유기간의 경과, 개인정보의 처리 목적 달성, 가명정보의 처리 기간 경과 등 그 개인정보가 불필요하게 되었을 때에는 지체 없이 그 개인정보를 파기하여야 한다. 다만, 다른 법령에 따라 보존하여야 하는 경우에는 그러하지 아니하다. 개인정보 보호법 제30조(개인정보 처리방침의 수립 및 공개) ① 개인정보처리자는 다음 각 호의 사항이 포함된 개인정보의 처리 방침(이하 "개인정보 처리방침"이라 한다)을 정하여야 한다. 3의2. 개인정보의 파기절차 및 파기방법(제21조제1항 단서에 따라 개인정보를 보존하여야 하는 경우에는 그 보존근거와 보존하는 개인정보 항목을 포함한다)	개인정보 수집 동의서와 개인정보처리방침의 보유 기간이 일치하며 지체 없이 파기하도록 수정.

개인정보 처리방침 진단 결과 (5/14)

통제항목 번호	점검 기준
3.5.1.1	개인정보 처리방침을 법령에서 요구하는 내용을 모두 포함하여 알기 쉬운 용어로 구체적이고 명확하게 작성하였는가?

취약점	법령근거	개선방안
■ 처리하는 개인정보 항목 회사는 다음의 개인정보 항목을 처리하고 있습니다. 1. 회원 가입 및 서비스 제공 • 필수항목 : 이메일, 비밀번호, 성명, 핸드폰번호, 공인영어성적, 대학교명, 학과명, 학점, 자기소개서 • 선택항목 : 질병유무, 보유질병명 2. 회사는 만 14세 미만 아동의 홈페이지를 통한 회원가입 및 서비스 이용을 제한하고 있습니다. 수집 목적에 따라 구분하지 않고 회원 가입 및 서비스 제공을 일괄 처리함.	개인정보 보호법 제16조(개인정보의 수집 제한) ① 개인정보처리자는 제15조제1항 각 호의 어느 하나에 해당하여 개인정보를 수집하는 경우에는 그 목적에 필요한 최소한의 개인정보를 수집하여야 한다. 이 경우 최소한의 개인정보 수집이라는 입증책임은 개인정보처리자가 부담한다.	회원 가입에 필요한 개인정보와 서비스 제공에 필요한 개인정보를 목적에 따라 구분하여 수집 및 처리하도록 수정.

개인정보 처리방침 진단 결과 (6/14)

통제항목 번호	점검 기준
3.3.2.1	개인정보 처리업무를 제3자에게 위탁(재위탁 포함)하는 경우 인터넷 홈페이지 등에 위탁하는 업무의 내용과 수탁자를 현행화하여 공개하고 있는가?

취약점	법령근거	개선방안
■ 개인정보의 제3자 제공 ① 회사는 정보주체의 개인정보를 개인정보의 처리 목적에서 명시한 범위 내에서만 처리하며, 정보주체의 동의, 법률의 특별한 규정 등 「개인정보 보호법」 제17조 및 제18조에 해당하는 경우에만 개인정보를 제3자에게 제공하고 그 이외에는 정보주체의 개인정보를 제3자에게 제공하지 않습니다. ② 회사는 원활한 서비스 제공을 위해 다음의 경우 정보주체의 동의를 얻어 필요 최소한의 범위로만 제공합니다. 제공받는 자 / 제공목적 / 제공항목 / 보유 및 이용기간 ㈜ABC / 합격 여부 알림 및 일자리 소개를 위한 SMS 발송 / 핸드폰번호 / SMS 발송 후, 1개월 보관 후 파기 처리업무 위탁을 제3자 제공으로 기재함.	개인정보 보호법 제26조(업무위탁에 따른 개인정보의 처리 제한) ② 제1항에 따라 개인정보의 처리 업무를 위탁하는 개인정보처리자(이하 "위탁자"라 한다)는 위탁하는 업무의 내용과 개인정보 처리 업무를 위탁받아 처리하는 자(개인정보 처리 업무를 위탁받아 처리하는 자로부터 위탁받은 업무를 다시 위탁받은 제3자를 포함하며, 이하 "수탁자"라 한다)를 정보주체가 언제든지 쉽게 확인할 수 있도록 대통령령으로 정하는 방법에 따라 공개하여야 한다.	개인정보 처리 업무 위탁에 해당하는 경우, 이를 제3자 제공과 구분하여 '개인정보 처리 위탁'으로 명시하고, 위탁 업무의 내용과 수탁자를 공개하도록 수정.

개인정보 처리방침 진단 결과 (7/14)

통제항목 번호	점검 기준
3.5.1.1	개인정보 처리방침을 법령에서 요구하는 내용을 모두 포함하여 알기 쉬운 용어로 구체적이고 명확하게 작성하였는가?

취약점	법령근거	개선방안
회사는 다음의 개인정보 항목을 처리하고 있습니다. 1. 회원 가입 및 서비스 제공 • 필수항목 : 이메일, 비밀번호, 성명, 핸드폰번호, 공인영어성적, 대학교명, 학과명, 학점, 자기소개서 • 선택항목 : 질병유무, 보유질병명 2. 회사는 만 14세 미만 아동의 홈페이지를 통한 회원가입 및 서비스 이용을 제한하고 있습니다. <자동화된 결정 과정에서 민감정보 또는 14세 미만 아동의 개인정보를 처리하는 경우 그 목적 및 처리하는 개인정보의 구체적인 항목> - 당사는 자동화된 결정 과정에서 민감정보 및 14세 미만 아동의 개인정보를 처리하지 않습니다. 질병유무, 보유질병명 등 민감정보를 수집 및 처리하고 있음에도 처리하지 않는다고 기재함.	개인정보 보호법 제30조(개인정보 처리방침의 수립 및 공개) ① 개인정보처리자는 다음 각 호의 사항이 포함된 개인정보의 처리 방침(이하 "개인정보 처리방침"이라 한다)을 정하여야 한다. 3의3. 제23조제3항에 따른 민감정보의 공개 가능성 및 비공개를 선택하는 방법(해당되는 경우에만 정한다)	민감정보인 '질병유무'와 '보유질병명'을 처리하고 있으므로, 개인정보 처리방침에 민감정보를 처리하지 않는다고 기재한 부분을 삭제 후 처리 목적 및 처리하는 개인정보의 구체적인 항목을 기재.

개인정보 처리방침 진단 결과 (8/14)

통제항목 번호	점검 기준
3.1.2.1	개인정보를 수집하는 경우 그 목적에 필요한 범위에서 최소한의 정보만을 수집하고 있는가?

취약점	법령근거	개선방안
채용 결정을 내리는 과정에서 지원자의 AI 서류전형 평가 점수가 채용의 판단 기준으로 활용됩니다. 채용 전형의 자동화된 시스템에 사용되는 지원자의 주요 개인정보 유형은 다음과 같습니다. - AI 서류전형 : 자기소개서 내용, 공인영어시험 점수, 대학성적 등 ② 자동화된 결정과의 관계 채용 결정을 내리는 과정에서 지원자에게 수집하는 주요 개인정보 유형 및 평가점수가 채용에 반영되는 비중은 다음과 같습니다. - AI 서류전형 : 자기소개서, 학부성적 등 (100%) 자동화된 결정에 사용되는 자기소개서, 학부성적 외에도 공인영어시험 점수를 불필요하게 수집하고 있음.	개인정보 보호법 제16조(개인정보의 수집 제한) ① 개인정보처리자는 제15조제1항 각 호의 어느 하나에 해당하여 개인정보를 수집하는 경우에는 그 목적에 필요한 최소한의 개인정보를 수집하여야 한다. 이 경우 최소한의 개인정보 수집이라는 입증책임은 개인정보처리자가 부담한다.	채용 결정에 사용되지 않는 공인영어시험 점수는 불필요한 정보이므로 수집을 중단하도록 수정.

개인정보 처리방침 진단 결과 (9/14)

통제항목 번호	점검 기준
3.5.1.1	개인정보 처리방침을 법령에서 요구하는 내용을 모두 포함하여 알기 쉬운 용어로 구체적이고 명확하게 작성하였는가?

취약점	법령근거	개선방안
채용 결정을 내리는 과정에서 지원자의 AI 서류전형 평가 점수가 채용의 판단 기준으로 활용됩니다. 채용 전형의 자동화된 시스템에 사용되는 지원자의 주요 개인정보 유형은 다음과 같습니다. - AI 서류전형 : 자기소개서 내용, 공인영어시험 점수, 대학성적 등 ② 자동화된 결정과의 관계 채용 결정을 내리는 과정에서 지원자에게 수집하는 주요 개인정보 유형 및 평가점수가 채용에 반영되는 비중은 다음과 같습니다. - AI 서류전형 : 자기소개서, 학부성적 등 (100%) 자동화된 결정에 사용되는 개인정보의 항목을 '~등'과 같이 추상적으로 기재함.	표준 개인정보 보호지침 제18조(개인정보 처리방침의 작성기준 등) ① 개인정보처리자는 개인정보 처리방침을 작성할 때 법 제30조 제1항 및 영 제31조제1항 각 호의 사항을 명시적으로 구분하되, 알기 쉬운 용어로 구체적이고 명확하게 표현해야 한다. 개인정보 보호법 시행령 제44조의4(자동화된 결정의 기준과 절차 등의 공개) ① 개인정보처리자는 법 제37조의2제4항에 따라 다음 각 호의 사항을 정보주체가 쉽게 확인할 수 있도록 인터넷 홈페이지 등을 통해 공개해야 한다. 2. 자동화된 결정에 사용되는 주요 개인정보의 유형과 자동화된 결정의 관계	자동화된 결정에 사용되는 개인정보 항목을 '~등'과 같이 모호한 표현을 사용하지 않고, 구체적이고 명확하게 기재하도록 수정.

개인정보 처리방침 진단 결과 (10/14)

통제항목 번호	점검 기준
3.5.1.1	개인정보 처리방침을 법령에서 요구하는 내용을 모두 포함하여 알기 쉬운 용어로 구체적이고 명확하게 작성하였는가?

취약점	법령근거	개선방안
■ 개인정보 자동 수집 장치의 설치·운영 및 거부에 관한 사항 ① 회사는 이용자에게 개별적인 맞춤서비스를 제공하기 위해 이용 정보를 저장하고 수시로 불러오는 '쿠키(cookie)'를 사용합니다. ② 쿠키는 웹사이트를 운영하는데 이용되는 서버(http)가 이용자의 컴퓨터 브라우저에게 보내는 소량의 정보이며 이용자들의 PC 컴퓨터 내의 하드디스크에 저장되기도 합니다. 가. 쿠키의 사용목적: 이용자가 방문한 각 서비스와 웹 사이트들에 대한 방문 및 이용형태, 인기 검색어, 보안접속 여부 등을 파악하여 이용자에게 최적화된 정보 제공을 위해 사용됩니다. 나. 쿠키의 설치·운영 및 거부 : 웹브라우저 상단의 도구>인터넷 옵션>개인정보 메뉴의 옵션 설정을 통해 쿠키 저장을 거부 할 수 있습니다. 자동 수집 장치의 설치·운영 및 거부에 관한 사항에서 정보주체를 식별하여 행태 정보를 처리하는 경우, 개인정보에 해당함. 그러나 법적근거, 보유 및 이용 기간이 누락되었으며 수집방법과 목적이 모호하고, 수집항목이 '~등'과 같이 추상적으로 기재되어 있음. 또한 쿠키 거부 방법이 현행화되어 있지 않음.	표준 개인정보 보호지침 제19조 (개인정보 처리방침의 기재사항) ① 개인정보처리자가 개인정보 처리방침을 작성할 때에는 법 제 30조제1항에 따라 다음 각 호의 사항을 모두 포함하여야 한다. 6. 인터넷 접속정보파일 등 개인 정보를 자동으로 수집하는 장치의 설치 · 운영 및 그 거부에 관한 사항(해당되는 경우에만 정한다)	수집 항목을 '~등'과 같이 추상적인 표현이 아닌 구체적으로 명시하도록 수정. 수집 방법과 목적, 보유 및 이용 기간, 법적 근거를 명확히 기재하도록 수정. 쿠키 거부 방법이 최신화된 내용으로 현행화되었는지 확인하여 수정.

개인정보 처리방침 진단 결과 (11/14)

통제항목 번호	점검 기준
3.5.1.1	개인정보 처리방침을 법령에서 요구하는 내용을 모두 포함하여 알기 쉬운 용어로 구체적이고 명확하게 작성하였는가?

취약점	법령근거	개선방안
■ 권익침해 구제방법 ① 정보주체는 개인정보침해로 인한 구제를 받기 위하여 개인정보분쟁조정위원회, 한국인터넷진흥원 개인정보침해신고센터 등에 분쟁해결이나 상담 등을 신청할 수 있습니다. 이 밖에 기타 개인정보침해의 신고, 상담에 대하여는 아래의 기관에 문의하시기 바랍니다. 1. 개인정보 분쟁조정위원회 : (국번없이) 1833-6972 (www.kopico.go.kr) 2. 개인정보침해 신고센터 : (국번없이) 118 (privacy.kisa.or.kr) 3. 대검찰청 사이버수사과 : (국번없이) 1301 (www.spo.go.kr) 4. 경찰청 사이버수사국 : (국번없이) 182 (www.safe182.go.kr) 경찰청 사이버수사국의 홈페이지 주소는 www.safe182.go.kr이 아니라 ecrm.cyber.go.kr임에도 오기재됨.	표준 개인정보 보호지침 제19조(개인정보 처리방침의 기재사항) ① 개인정보처리자가 개인정보 처리방침을 작성할 때에는 법 제30조제1항에 따라 다음 각 호의 사항을 모두 포함하여야 한다. 17. 정보주체의 권익침해에 대한 구제방법	권장 사항이지만 웹사이트 주소를 현행화하여 정보주체에게 혼란을 주지 않도록 하여야 함. 경찰청 사이버수사국 홈페이지 주소를 ecrm.cyber.go.kr로 수정.

개인정보 처리방침 진단 결과 (12/14)

통제항목 번호	점검 기준
3.1.4.3	재화 또는 서비스를 제공하는 과정에서 공개되는 정보에 정보주체의 민감정보가 포함됨으로써 사생활 침해의 위험성이 있다고 판단하는 때에는 재화 또는 서비스의 제공 전에 민감정보의 공개 가능성 및 비공개를 선택하는 방법을 정보주체가 알아보기 쉽게 알리고 있는가?

취약점	법령근거	개선방안
민감정보의 공개 가능성 및 비공개를 선택하는 방법에 관한 사항이 기재되지 않음.	개인정보 보호법 제23조(민감정보의 처리 제한) ③ 개인정보처리자는 재화 또는 서비스를 제공하는 과정에서 공개되는 정보에 정보주체의 민감정보가 포함됨으로써 사생활 침해의 위험성이 있다고 판단하는 때에는 재화 또는 서비스의 제공 전에 민감정보의 공개 가능성 및 비공개를 선택하는 방법을 정보주체가 알아보기 쉽게 알려야 한다.	민감정보가 서비스 제공 과정에서 공개될 가능성이 있는 경우, 정보주체에게 민감정보의 공개 가능성 및 비공개 선택 방법을 미리 알리도록 수정.

개인정보 처리방침 진단 결과 (13/14)

통제항목 번호	점검 기준	
3.5.1.1	개인정보 처리방침을 법령에서 요구하는 내용을 모두 포함하여 알기 쉬운 용어로 구체적이고 명확하게 작성하였는가?	
취약점	**법령근거**	**개선방안**
정보주체와 법정대리인의 권리·의무 및 행사 방법에 관한 사항이 기재되지 않음.	개인정보 보호법 제30조(개인정보 처리방침의 수립 및 공개) ① 개인정보처리자는 다음 각 호의 사항이 포함된 개인정보의 처리 방침(이하 "개인정보 처리방침"이라 한다)을 정하여야 한다. 5. 정보주체와 법정대리인의 권리·의무 및 그 행사방법에 관한 사항	정보주체와 법정대리인의 권리·의무 및 그 행사 방법에 관한 사항을 필수적으로 포함하여 기재하도록 수정. 해당 개인정보처리자에 대해 정보주체가 지니는 개인정보 열람, 전송 요구, 정정·삭제, 처리정지, 동의철회, 자동화된 결정 거부·설명 요구 등(이하 '열람 등') 행사방법, 행사절차 등을 구체적으로 기재.

개인정보 처리방침 진단 결과 (14/14)

통제항목 번호	점검 기준	
3.5.1.3	개인정보 처리방침이 변경되는 경우 사유 및 변경 내용을 지체 없이 공지하고 정보주체가 언제든지 변경된 사항을 쉽게 알아 볼 수 있도록 조치하고 있는가?	
취약점	**법령근거**	**개선방안**
처리방침 변경 시 공지방법·시기가 불명확함.	개인정보 보호법 제30조(개인정보 처리방침의 수립 및 공개) ② 개인정보처리자가 개인정보 처리방침을 수립하거나 변경하는 경우에는 정보주체가 쉽게 확인할 수 있도록 대통령령으로 정하는 방법에 따라 공개하여야 한다. 표준 개인정보 보호지침 제21조(개인정보 처리방침의 변경) 개인정보처리자가 개인정보 처리방침을 변경하는 경우에는 변경 및 시행의 시기, 변경된 내용을 지속적으로 공개하여야 하며, 변경된 내용은 정보주체가 쉽게 확인할 수 있도록 변경 전·후를 비교하여 공개하여야 한다.	개인정보 처리방침 변경 시, 변경 및 시행 시기를 명확하게 공지하고, 이전의 개인정보 처리방침이 있는 경우에는 그간의 변경 이력을 기재하여야 하며, 변경 전·후 내용을 비교하여 공개하거나 변경의 주요 내용을 별도로 안내하는 등 정보주체가 변경된 사항을 쉽게 알 수 있도록 수정.

(주)알바월드

개인정보 위탁계약서 진단 결과

개인정보 처리 위탁계약서 진단 결과 (1/2)

통제항목 번호	점검 기준	
2.3.2.2	외부 서비스 이용 및 업무 위탁에 따른 정보보호 및 개인정보보호 요구사항을 식별하고 이를 계약서 또는 협정서에 명시하고 있는가?	
취약점	**법령근거**	**개선방안**
재위탁 제한에 대한 내용 없음.	개인정보 보호법 제26조(업무위탁에 따른 개인정보의 처리 제한) ① 개인정보처리자가 제3자에게 개인정보의 처리 업무를 위탁하는 경우에는 다음 각 호의 내용이 포함된 문서로 하여야 한다. 3. 그 밖에 개인정보의 안전한 관리를 위하여 대통령령으로 정한 사항 개인정보 보호법 시행령 제28조(개인정보의 처리 업무 위탁 시 조치) ① 법 제26조제1항제3호에서 "대통령령으로 정한 사항"이란 다음 각 호의 사항을 말한다. 2. 재위탁 제한에 관한 사항	개인정보 처리 위탁 계약서에 개인정보의 안전한 관리를 위한 재위탁 제한에 관한 사항을 포함하도록 수정.

개인정보 처리 위탁계약서 진단 결과 (2/2)

통제항목 번호	점검 기준
2.3.2.2	외부 서비스 이용 및 업무 위탁에 따른 정보보호 및 개인정보보호 요구사항을 식별하고 이를 계약서 또는 협정서에 명시하고 있는가?

취약점	법령근거	개선방안
제9조 (개인정보의 파기) ① "을"은 제4항의 위탁업무기간이 종료되면 특별한 사유가 없는 한 지체 없이 개인정보를 파기하고 이를 "갑"에게 확인받아야 한다. '4항'을 '4조'로 수정하여야 함.	개인정보 보호법 제26조(업무위탁에 따른 개인정보의 처리 제한) ① 개인정보처리자가 제3자에게 개인정보의 처리 업무를 위탁하는 경우에는 다음 각 호의 내용이 포함된 문서로 하여야 한다.	계약서 제9조 제1항에서 언급하는 '제4항'을 위탁 업무 기간을 규정한 '제4조'로 수정.

(주)알바월드

개인정보처리시스템 진단 결과

개인정보처리시스템 진단 결과 (1/12)

통제항목 번호	점검 기준
2.2.5.2	조직 내 인력(임직원, 임시직원, 외주용역직원 등)의 퇴직 또는 직무변경 시 지체 없는 정보자산 반납, 접근권한 회수·조정, 결과 확인 등의 절차를 수립·이행하고 있는가?

취약점	법령근거	개선방안
사용자 퇴직 및 인사이동 발생 시, 해당일로부터 3개월 경과 후, 자동으로 접속 차단 및 계정을 정지시킴.	개인정보의 안전성 확보조치 기준 제5조(접근 권한의 관리) ② 개인정보처리자는 개인정보취급자 또는 개인정보취급자의 업무가 변경되었을 경우 지체 없이 개인정보처리시스템의 접근 권한을 변경 또는 말소하여야 한다.	개인정보취급자의 퇴직 또는 업무 변경 시, 계정 및 접근 권한을 지체 없이 변경하거나 말소하도록 절차를 수정.

개인정보처리시스템 진단 결과 (2/12)

통제항목 번호	점검 기준	
2.5.3.2	정보통신망을 통하여 외부에서 개인정보처리시스템에 접속하려는 경우에는 법적 요구사항에 따라 안전한 인증수단 또는 안전한 접속수단을 적용하고 있는가?	
취약점	**법령근거**	**개선방안**
외부에서 인터넷을 통해 접속하는 경우에는, ID/PW 이외 사번을 추가로 입력하도록 운영하고 있음.	개인정보의 안전성 확보조치 기준 제6조(접근통제) ② 개인정보처리자는 개인정보취급자가 정보통신망을 통해 외부에서 개인정보처리시스템에 접속하려는 경우 인증서, 보안토큰, 일회용 비밀번호 등 안전한 인증수단을 적용하여야 한다. 다만, 이용자가 아닌 정보주체의 개인정보를 처리하는 개인정보처리시스템의 경우 가상사설망 등 안전한 접속수단 또는 안전한 인증수단을 적용할 수 있다.	외부에서 개인정보처리시스템에 접속할 경우, ID/PW 외에 인증서, 보안토큰, 일회용 비밀번호(OTP) 등 안전한 인증수단을 적용하도록 조치.

개인정보처리시스템 진단 결과 (3/12)

통제항목 번호	점검 기준
2.6.2.2	정보시스템에 접속 후 일정시간 업무처리를 하지 않는 경우 자동으로 시스템 접속이 차단되도록 하고 있는가?

취약점	법령근거	개선방안
업무 시간 동안에는 고객상담을 위해 세션타임아웃을 12시간으로 설정하고 있음.	개인정보의 안전성 확보조치 기준 제6조(접근통제) ④ 개인정보처리자는 개인정보처리시스템에 대한 불법적인 접근 및 침해사고 방지를 위하여 개인정보취급자가 일정시간 이상 업무처리를 하지 않는 경우에는 자동으로 접속이 차단되도록 하는 등 필요한 조치를 하여야 한다.	개인정보취급자가 일정 시간 이상 업무 처리를 하지 않을 경우, 자동으로 접속이 차단되도록 세션 타임아웃 시간을 10분에서 60분 이내로 단축하도록 조치.

개인정보처리시스템 진단 결과 (4/12)

통제항목 번호	점검 기준	
2.7.1.1	개인정보 및 주요정보의 보호를 위하여 법적 요구사항을 반영한 암호화 대상, 암호강도, 암호사용 등이 포함된 암호정책을 수립하고 있는가?	
취약점	**법령근거**	**개선방안**
전송구간에 대해 TLS1.1 버전의 암호화를 적용하고 있음.	개인정보의 안전성 확보조치 기준 제7조(개인정보의 암호화) ④ 개인정보처리자는 개인정보를 정보통신망을 통하여 인터넷망 구간으로 송·수신하는 경우에는 이를 안전한 암호 알고리즘으로 암호화하여야 한다.	TLS 1.1 버전은 짧은 길이 키를 사용하는 DES 암호화 알고리즘을 지원하여 취약점이 있으므로, TLS 1.2 또는 TLS 1,3 등 더 안전한 최신 버전으로 업데이트하도록 조치.

개인정보처리시스템 진단 결과 (5/12)

통제항목 번호	점검 기준
2.7.1.1	개인정보 및 주요정보의 보호를 위하여 법적 요구사항을 반영한 암호화 대상, 암호강도, 암호사용 등이 포함된 암호정책을 수립하고 있는가?

취약점	법령근거	개선방안
사용자 비밀번호를 DB에 저장 시, AES256 암호화 알고리즘으로 암호화 저장하고 있음.	개인정보의 안전성 확보조치 기준 제7조(개인정보의 암호화) ① 개인정보처리자는 비밀번호, 생체인식정보 등 인증정보를 저장 또는 정보통신망을 통하여 송·수신하는 경우에 이를 안전한 암호 알고리즘으로 암호화하여야 한다. 다만, 비밀번호를 저장하는 경우에는 복호화되지 아니하도록 일방향 암호화하여 저장하여야 한다.	사용자 비밀번호를 데이터베이스에 저장할 때 복호화되지 않도록 SHA-224/256/384/512 등 일방향 암호화(해시 함수)를 적용하도록 조치.

개인정보처리시스템 진단 결과 (6/12)

통제항목 번호	점검 기준		
2.9.5.3	개인정보처리시스템의 접속기록은 관련 법령에서 정한 주기에 따라 정기적으로 점검하고 있는가?		
취약점	법령근거	개선방안	
사용자 접속로그는 분기 1회 이상 검토하여 이상유무를 개인정보 보호책임자에게 보고 및 조치를 진행하고 있음.	개인정보의 안전성 확보조치 기준 제8조(접속기록의 보관 및 점검) ② 개인정보처리자는 개인정보의 오·남용, 분실 도난 유출·위조·변조 또는 훼손 등에 대응하기 위하여 개인정보처리시스템의 접속기록 등을 월 1회 이상 점검하여야 한다. 특히 개인정보의 다운로드가 확인된 경우에는 내부 관리계획 등으로 정하는 바에 따라 그 사유를 반드시 확인하여야 한다.	개인정보처리시스템의 접속 기록을 월 1회 이상 점검하도록 조치.	

개인정보처리시스템 진단 결과 (7/12)

통제항목 번호	점검 기준	
2.6.3.5	개인정보 및 중요정보의 불필요한 노출(조회, 화면표시, 인쇄, 다운로드 등)을 최소화할 수 있도록 응용프로그램을 구현하여 운영하고 있는가?	
취약점	**법령근거**	**개선방안**
‘이용자 정보 추출’ 화면에서 화면에 출력되는 회원정보에 대해 별도 마스킹을 적용하지 않음.	개인정보의 안전성 확보조치 기준 제12조(출력·복사시 안전조치) ① 개인정보처리자는 개인정보처리시스템에서 개인정보의 출력시(인쇄, 화면표시, 파일생성 등) 용도를 특정하여야 하며, 용도에 따라 출력 항목을 최소화하여야 한다.	개인정보처리시스템에서 개인정보를 화면에 표시할 때, 출력 항목을 최소화하고 마스킹 처리를 적용하도록 조치.

개인정보처리시스템 진단 결과 (8/12)

통제항목 번호	점검 기준
2.6.3.5	개인정보 및 중요정보의 불필요한 노출(조회, 화면표시, 인쇄, 다운로드 등)을 최소화할 수 있도록 응용프로그램을 구현하여 운영하고 있는가?

취약점	법령근거	개선방안
‘회원관리’ 화면에서 고객정보 조회 시, 업무상 필요하여 LIKE 검색을 이용하고 있음.	개인정보 보호법 제3조(개인정보 보호 원칙) ⑥ 개인정보처리자는 정보주체의 사생활 침해를 최소화하는 방법으로 개인정보를 처리하여야 한다.	개인정보 검색 시에는 불필요하거나 과도한 정보가 조회되지 않도록 'LIKE 검색'을 제한하고, 일치 검색(equal 검색) 또는 두 가지 항목 이상의 검색 조건을 사용하도록 조치.

개인정보처리시스템 진단 결과 (9/12)

통제항목 번호	점검 기준
2.9.4.3	개인정보처리시스템에 대한 접속기록은 법적 요구사항을 준수할 수 있도록 필요한 항목을 모두 포함하여 일정기간 안전하게 보관하고 있는가?

취약점	법령근거	개선방안
<table><tr><th>NO</th><th>접속ID</th><th>접속일시</th><th>접속IP</th><th>수행업무</th></tr><tr><td>001</td><td>gildong</td><td>2025.08.01 13:10</td><td>192.168.1.3</td><td>조회</td></tr><tr><td>002</td><td>gildong</td><td>2025.09.10 09.30</td><td>192.168.1.3</td><td>조회</td></tr><tr><td>003</td><td>gildong</td><td>2025.09.13 11:25</td><td>192.168.1.3</td><td>수정</td></tr></table> 접속로그 관리 화면에서 처리한 정보주체의 정보에 대한 기록을 확인할 수 없음.	개인정보의 안전성 확보조치 기준 제2조(정의) 3. "접속기록"이란 개인정보처리시스템에 접속하는 자가 개인정보처리시스템에 접속하여 수행한 업무내역에 대하여 식별자, 접속일시, 접속지 정보, 처리한 정보주체 정보, 수행업무 등을 전자적으로 기록한 것을 말한다. 개인정보의 안전성 확보조치 기준 제8조(접속기록의 보관 및 점검) ① 개인정보처리자는 개인정보취급자의 개인정보처리시스템에 대한 접속기록을 1년 이상 보관·관리하여야 한다. 다만, 다음 각 호의 어느 하나에 해당하는 경우에는 2년 이상 보관·관리하여야 한다. 1. 5만명 이상의 정보주체에 관한 개인정보를 처리하는 개인정보처리시스템에 해당하는 경우 2. 고유식별정보 또는 민감정보를 처리하는 개인정보처리시스템에 해당하는 경우 3. 개인정보처리자로서 「전기통신사업법」제6조제1항에 따라 등록을 하거나 같은 항 단서에 따라 신고한 기간통신사업자에 해당하는 경우	개인정보처리시스템 접속 기록에 필수 항목인 '처리한 정보주체의 정보'를 포함하도록 수정.

개인정보처리시스템 진단 결과 (10/12)

통제항목 번호	점검 기준
2.7.1.2	암호정책에 따라 개인정보 및 주요정보의 저장, 전송, 전달 시 암호화를 수행하고 있는가?

취약점	법령근거	개선방안
이용자의 개인정보를 인터넷망으로 송수신 또는 개인정보취급자 컴퓨터, 모바일기기, 보조저장매체 등에 저장 시 안전한 알고리즘으로 암호화를 해야 하나 엑셀을 다운받고 업로드하는 등 개인정보 유출의 위험이 크며 악성코드 감염에 취약함.	개인정보의 안전성 확보조치 기준 제7조(개인정보의 암호화) ⑤ 개인정보처리자는 이용자의 개인정보 또는 이용자가 아닌 정보주체의 고유식별정보, 생체인식정보를 개인정보취급자의 컴퓨터, 모바일 기기 및 보조저장매체 등에 저장할 때에는 안전한 암호 알고리즘을 사용하여 암호화한 후 저장하여야 한다. 개인정보의 안전성 확보조치 기준 제12조(출력·복사시 안전조치) ② 개인정보처리자는 개인정보가 포함된 종이 인쇄물, 개인정보가 복사된 외부 저장매체 등 개인정보의 출력·복사물을 안전하게 관리하기 위해 필요한 안전조치를 하여야 한다.	이용자의 개인정보를 개인정보취급자의 컴퓨터, 모바일 기기 및 보조저장매체 등에 저장할 때 안전한 암호 알고리즘을 사용하도록 수정. 개인정보가 포함된 출력물이나 복사물(엑셀 파일)을 안전하게 관리하기 위한 보호조치를 마련하도록 설정.

개인정보처리시스템 진단 결과 (11/12)

통제항목 번호	점검 기준		
2.10.5.1	외부 조직에 개인정보 및 중요정보를 전송할 경우 안전한 전송 정책을 수립하고 있는가?		
취약점	법령근거	개선방안
이용자의 개인정보가 담긴 엑셀 파일을 외부 조직에 전송하면서 이메일을 사용하고 있어 개인정보 유출 또는 침해사고 발생의 위험이 매우 높음.	개인정보의 안전성 확보조치 기준 제7조(개인정보의 암호화) ④ 개인정보처리자는 개인정보를 정보통신망을 통하여 인터넷망 구간으로 송·수신하는 경우에는 이를 안전한 암호 알고리즘으로 암호화하여야 한다. 개인정보의 안전성 확보조치 기준 제12조(출력·복사시 안전조치) ② 개인정보처리자는 개인정보가 포함된 종이 인쇄물, 개인정보가 복사된 외부 저장매체 등 개인정보의 출력·복사물을 안전하게 관리하기 위해 필요한 안전조치를 하여야 한다.	개인정보 파일을 이메일로 전송할 경우, 파일을 암호화하고 암호는 별도의 안전한 채널을 통해 전달하는 등 조치.

개인정보처리시스템 진단 결과 (12/12)

통제항목 번호	점검 기준
2.6.6.3 2.7.10.5	재택근무, 원격협업, 스마트워크 등과 같은 원격업무 수행 시 중요정보 유출, 해킹 등 침해사고 예방을 위한 보호대책을 수립·이행하고 있는가? 개인정보 또는 중요정보가 포함된 보조저장매체를 잠금장치가 있는 안전한 장소에 보관하고 있는가?

취약점	법령근거	개선방안
재택근무 시 보안조치가 부족하며 이용자의 개인정보가 포함된 엑셀 파일을 다운로드한 보안USB의 반출입이 가능한지 여부가 불확실함.	개인정보의 안전성 확보조치 기준 제10조(출력·복사시 안전조치) ② 개인정보처리자는 개인정보가 포함된 서류, 보조저장매체 등을 잠금장치가 있는 안전한 장소에 보관하여야 한다. ③ 개인정보처리자는 개인정보가 포함된 보조저장매체의 반출·입 통제를 위한 보안대책을 마련하여야 한다. 다만, 별도의 개인정보처리시스템을 운영하지 아니하고 업무용 컴퓨터 또는 모바일 기기를 이용하여 개인정보를 처리하는 경우에는 이를 적용하지 아니할 수 있다.	재택근무 시 개인정보가 포함된 보조저장매체의 반출입을 통제하기 위한 보안대책을 마련하고, 해당 매체에 대한 암호화 등 안전성 확보조치를 적용하도록 수정.

(주)알바월드

결론

결론

(주) 알바월드 취약점

총 33건

01

개인정보 수집 동의서 진단 결과

5건

02

개인정보 처리방침 진단 결과

14건

03

개인정보 위탁계약서 진단 결과

2건

04

개인정보처리시스템 진단 결과

12건

감사합니다

THANK YOU

BoB 14기 보안 컨설팅 손효림